

SkillsQuark

advanced technology & skill development

TASK 1 – RECONNAISSANCE & NMAP

Proof of Concept – Penetration Test Report

Target: Metasploitable 2 | Attacker: Kali Linux | 10–11 June 2026

Prepared By	SkillsQuark Security Research Team
Target	192.168.56.105 – Metasploitable 2 (VulnHub)
Attacker Machine	192.168.56.106 – Kali Linux
Network	VirtualBox Host-Only Adapter (Isolated Lab)
Tool Used	Nmap 7.98 – Aggressive Scan (-A)
Scan Date	10 June 2026
Report Date	11 June 2026
Classification	CONFIDENTIAL – Internal Use Only
Report Version	1.0 Final

Confidentiality Statement

CONFIDENTIAL DOCUMENT – RESTRICTED DISTRIBUTION

This document is prepared by SkillsQuark Security Research & Training Division and is classified CONFIDENTIAL. It contains sensitive security information including vulnerability details, exploitation techniques, and system weaknesses identified during an authorised, controlled security assessment.

This report is intended solely for named, authorised personnel directly involved in this SkillsQuark engagement. Unauthorised disclosure, reproduction, distribution, or use – in whole or in part – is strictly prohibited and may constitute a breach of applicable information security policies and legal obligations.

Recipients are required to:

- Store this document securely and restrict access on a strict need-to-know basis.
- Not share, forward, or publish this report without written authorisation from SkillsQuark.
- Destroy all copies – physical and digital – when no longer required for the stated purpose.
- Report any accidental disclosure immediately to the SkillsQuark security team.
- Not use any information herein to target systems outside the defined lab scope.

This report was prepared exclusively for educational and training purposes under the SkillsQuark curriculum. All findings relate solely to the Metasploitable 2 isolated lab environment and do not reflect the security posture of any production, third-party, or externally-facing system.

WARNING: The vulnerabilities described in this report are real and exploitable. This information must not be used outside the authorised lab environment.

© 2026 SkillsQuark | Security Research & Training Division | Classification: CONFIDENTIAL

Table of Contents

1. Executive Summary	4
2. Severity Distribution Chart	4
3. CVSS 3.1 Score Distribution Chart	5
4. OWASP Top 10 (2025) Mapping Chart	5
5. OWASP Top 10 (2025) Detailed Table	6
6. CVE Catalogue	6
7. Attack Surface Map – All 23 Ports	7
8. Proof of Concept – Step-by-Step	8
8.1 Step 1 – Download Target from VulnHub	
8.2 Step 2 – VirtualBox & Host-Only Network Setup	
8.3 Step 3 – Host Discovery (ARP Scan + netexec)	
8.4 Step 4 – Nmap Aggressive Scan (4 Screenshots)	
8.5 Step 5 – Attack Surface Map	
9. Key Risks & Recommendations	14
10. Disclaimer & Legal Notice	15

Note: Page numbers are approximate. Document uses automatic headers and footers.

1. Executive Summary

This report documents the complete proof-of-concept (PoC) reconnaissance and enumeration exercise conducted by SkillsQuark against Metasploitable 2 – a deliberately vulnerable Linux virtual machine deployed in an isolated VirtualBox lab. The assessment used Nmap 7.98 with aggressive flags (-A) to enumerate open ports, service versions, OS fingerprint, and network topology.

A total of 23 open TCP ports were identified. Five carry a CRITICAL severity (CVSS 3.1 ≥ 9.8), twelve are HIGH, five MEDIUM, and one LOW. Nine publicly disclosed CVEs were confirmed – several permitting unauthenticated remote code execution with root privileges and zero preconditions. Findings are fully mapped to OWASP Top 10 (2025), CWE identifiers, and CVSS 3.1 base scores.

2. Severity Distribution

The chart below shows the count of vulnerabilities by severity rating across all 23 open ports identified on the target.

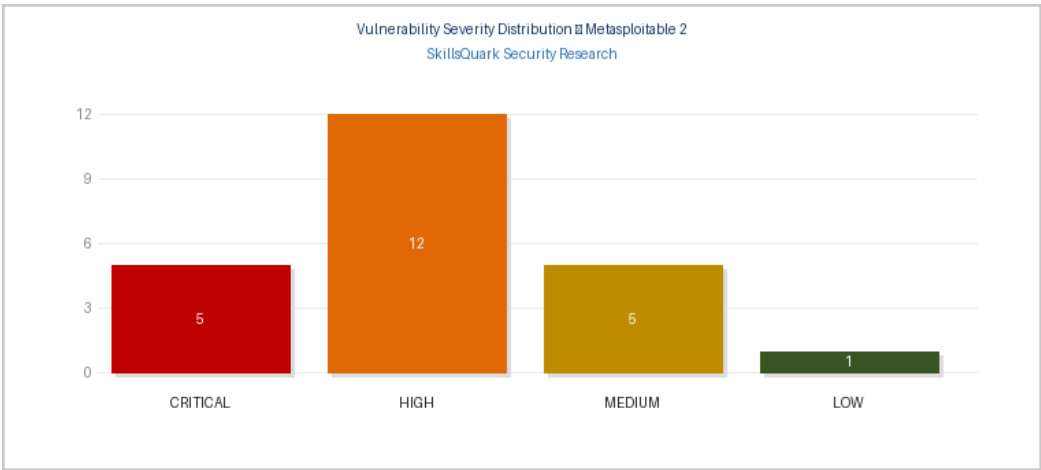


Figure 1 – Severity Distribution: Critical (5) | High (12) | Medium (5) | Low (1)

- CRITICAL (5): vsftpd backdoor, Samba RCE x2, UnrealIRCd backdoor, open bindshell – each yields unauthenticated root access.
- HIGH (12): EOL software, cleartext protocols, absent or trivially-bypassed authentication.
- MEDIUM (5): Information disclosure, deprecated cipher support, default credentials.
- LOW (1): X11 forwarding exposure – limited direct exploit potential.

3. CVSS 3.1 Score Distribution

CVSS 3.1 base scores for all identified vulnerabilities, sorted descending. Scores of 9.0–10.0 indicate network-exploitable, zero-complexity, no-privilege attack vectors – the highest possible risk tier.

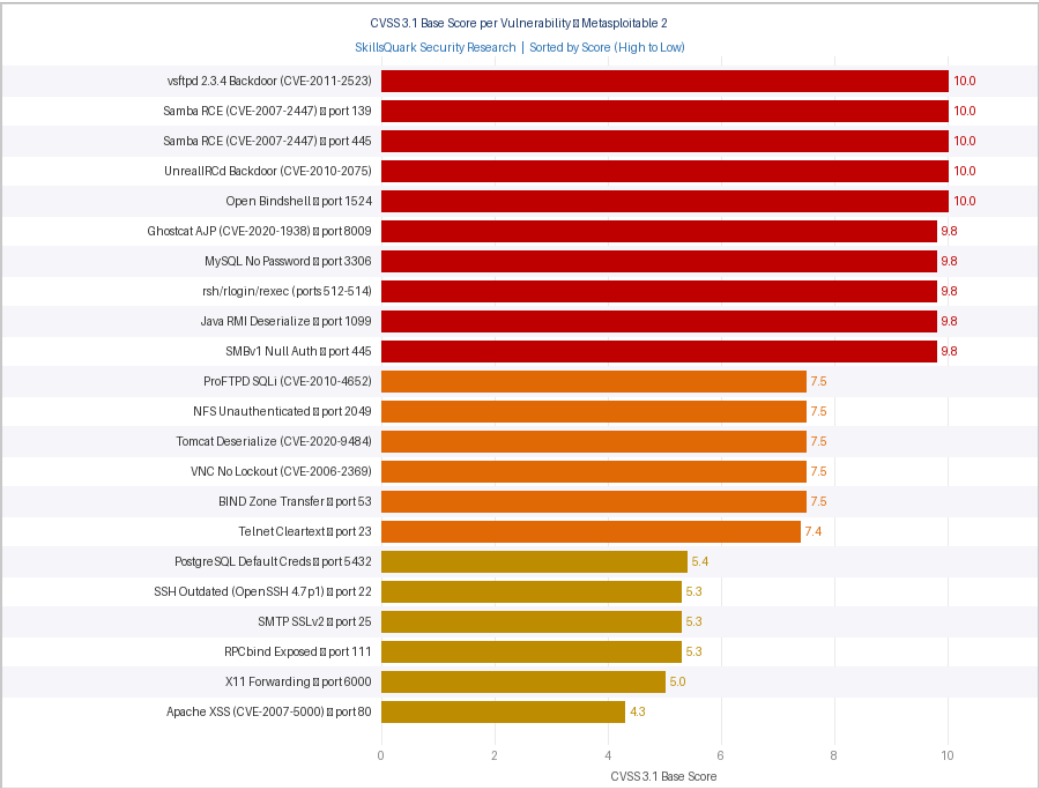


Figure 2 – CVSS 3.1 Base Scores (sorted high to low) | Red ≥9.0 Critical | Orange 7.0–8.9 High | Yellow 4.0–6.9 Medium

4. OWASP Top 10 (2025) – Affected Port Count

The bar chart below shows the number of affected ports per OWASP Top 10 (2025) category. Categories with the most affected ports represent the highest-priority remediation areas.

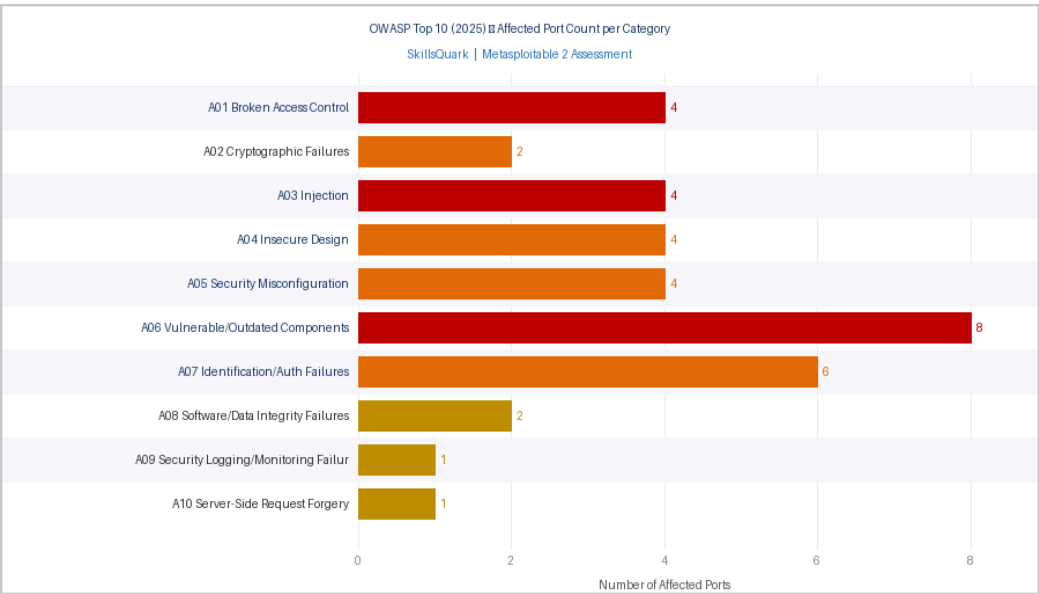


Figure 3 – OWASP Top 10 (2025): Number of Affected Ports per Category | Red = Critical exposure | Orange = High

5. OWASP Top 10 (2025) Detailed Mapping

All 23 discovered vulnerabilities mapped to the OWASP Top 10 (2025) framework. Nine of ten categories have direct port-level exposure confirmed via Nmap reconnaissance.

OWASP 2025 ID	Category	Mapped Ports / Services
A01:2025	Broken Access Control	111/tcp, 1524/tcp, 2049/tcp, 6000/tcp
A02:2025	Cryptographic Failures	23/tcp, 25/tcp
A03:2025	Injection	21/tcp, 139/tcp, 445/tcp, 2121/tcp (OS cmd / SQL injection)
A04:2025	Insecure Design	1524/tcp, 512-514/tcp (design-level auth absence)
A05:2025	Security Misconfiguration	22/tcp, 53/tcp, 3306/tcp, 5432/tcp
A06:2025	Vulnerable & Outdated Components	21/tcp, 80/tcp, 139/tcp, 445/tcp, 2121/tcp, 6667/tcp, 8009/tcp, 8180/tcp
A07:2025	Identification & Auth Failures	512/tcp, 513/tcp, 514/tcp, 3306/tcp, 5432/tcp, 5900/tcp
A08:2025	Software & Data Integrity Failures	1099/tcp, 8180/tcp
A09:2025	Security Logging & Monitoring Failures	N/A — requires runtime monitoring analysis
A10:2025	Server-Side Request Forgery (SSRF)	8009/tcp (CVE-2020-1938 Ghostcat via AJP)

Note: A09 (Security Logging & Monitoring Failures) requires runtime analysis beyond passive reconnaissance to confirm exposure.

6. CVE Catalogue

All confirmed CVEs mapped against the discovered service versions. Verify current CVSS scores at nvd.nist.gov. All scores shown are CVSS 3.1 Base Score.

CVE ID	Port	Service	Risk	CVSS	Description
CVE-2011-2523	21/tcp	FTP	CRITICAL	10.0	Deliberate backdoor; ':' triggers root shell on port 6200
CVE-2007-5000	80/tcp	HTTP	HIGH	4.3	EOL Apache — XSS and DoS vulnerabilities confirmed
CVE-2007-2447	139/tcp	NetBIOS-SMB	CRITICAL	10.0	RCE via username map script; unauthenticated root
CVE-2007-2447	445/tcp	SMB	CRITICAL	10.0	SMBv1 + null auth = trivial RCE as root
CVE-2010-4652	2121/tcp	FTP	HIGH	7.5	SQL injection via TELNET IAC sequence in ProFTPD
CVE-2006-2369	5900/tcp	VNC	HIGH	7.5	No account lockout; brute-force trivially succeeds
CVE-2010-	6667/tcp	IRC	CRITICAL	10.0	Deliberate backdoor — unauthenticated RCE as root

CVE ID	Port	Service	Risk	CVSS	Description
2075					
CVE-2020-1938	8009/tcp	AJP	CRITICAL	9.8	Ghostcat — arbitrary file read and RCE via AJP
CVE-2020-9484	8180/tcp	Tomcat	HIGH	7.5	Default manager creds + deserialization RCE

7. Attack Surface Map – All 23 Open Ports

Complete enumeration of all 23 open TCP ports with service, version, risk, CVSS 3.1, CVE, CWE, OWASP (2025) mapping, and impact notes.

Port	Service	Version	Risk	CVSS	CVE	CWE	OWASP	Notes
21/tcp	FTP	vsftpd 2.3.4	CRITICAL	10.0	CVE-2011-2523	CWE-78	A06:2025	Deliberate backdoor; ';' triggers root shell on port 6200
22/tcp	SSH	OpenSSH 4.7p1 Debian	MEDIUM	5.3	N/A	CWE-327	A05:2025	EOL version – multiple unpatched vulnerabilities
23/tcp	Telnet	Linux telnetd	HIGH	7.4	N/A	CWE-319	A02:2025	Cleartext protocol; credentials interceptable in transit
25/tcp	SMTP	Postfix smtpd	MEDIUM	5.3	N/A	CWE-326	A02:2025	SSLv2 supported – broken, deprecated encryption
53/tcp	DNS	ISC BIND 9.4.2	HIGH	7.5	N/A	CWE-200	A05:2025	Zone transfer enabled; leaks full DNS record set
80/tcp	HTTP	Apache httpd 2.2.8	HIGH	4.3	CVE-2007-5000	CWE-79	A06:2025	EOL Apache – XSS and DoS vulnerabilities confirmed
111/tcp	RPCbind	RPC #100000	MEDIUM	5.3	N/A	CWE-284	A01:2025	Exposes NFS share list to unauthenticated clients
139/tcp	NetBIOS-SMB	Samba 3.X-4.X	CRITICAL	10.0	CVE-2007-2447	CWE-78	A06:2025	RCE via username map script; unauthenticated root
445/tcp	SMB	Samba 3.0.20-Debian	CRITICAL	10.0	CVE-2007-2447	CWE-78	A06:2025	SMBv1 + null auth = trivial RCE as root
512/tcp	rexec	netkit-rsh rexecd	HIGH	9.8	N/A	CWE-306	A07:2025	Trusted-host auth; bypassable without credentials
513/tcp	rlogin	rlogind	HIGH	9.8	N/A	CWE-306	A07:2025	No authentication – direct login without password
514/tcp	rsh	Netkit rshd	HIGH	9.8	N/A	CWE-306	A07:2025	Unauthenticated remote shell; inherently insecure
1099/tcp	Java RMI	GNU Classpath grmiregistry	HIGH	9.8	N/A	CWE-502	A08:2025	Insecure Java deserialization over RMI – RCE possible
1524/tcp	Bindshell	Metasploitable root shell	CRITICAL	10.0	N/A	CWE-306	A01:2025	Pre-opened root shell – connect = instant root access
2049/tcp	NFS	NFS 2-4 (RPC #100003)	HIGH	7.5	N/A	CWE-284	A01:2025	Unauthenticated NFS share enumeration and mounting
2121/tcp	FTP	ProFTPD 1.3.1	HIGH	7.5	CVE-2010-4652	CWE-89	A06:2025	SQL injection via TELNET IAC sequence in ProFTPD
3306/tcp	MySQL	MySQL 5.0.51a-3ubuntu5	CRITICAL	9.8	N/A	CWE-521	A07:2025	Root account has no password – full DB access
5432/tcp	PostgreSQL	PostgreSQL 8.3.0-8.3.7	MEDIUM	5.4	N/A	CWE-521	A07:2025	Default/weak credentials configured

Port	Service	Version	Risk	CVSS	CVE	CWE	OWASP	Notes
5900/tcp	VNC	Protocol 3.3	HIGH	7.5	CVE-2006-2369	CWE-307	A07:2025	No account lockout; brute-force trivially succeeds
6000/tcp	X11	(access denied)	MEDIUM	5.0	N/A	CWE-284	A01:2025	X11 forwarding exposed — display/input hijack risk
6667/tcp	IRC	UnrealIRCd	CRITICAL	10.0	CVE-2010-2075	CWE-78	A06:2025	Deliberate backdoor — unauthenticated RCE as root
8009/tcp	AJP	Apache Jserv 1.3	CRITICAL	9.8	CVE-2020-1938	CWE-918	A10:2025	Ghostcat — arbitrary file read and RCE via AJP
8180/tcp	Tomcat	Apache Tomcat 5.5	HIGH	7.5	CVE-2020-9484	CWE-502	A06:2025	Default manager creds + deserialization RCE

8. Proof of Concept – Step-by-Step

The following section documents the complete PoC workflow exactly as executed, including all terminal commands, output, and screenshots.

8.1 Step 1 – Download Target from VulnHub

Metasploitable 2 was downloaded from VulnHub – a deliberately vulnerable Linux VM created by Rapid7/Metasploit for penetration testing practice.

URL: www.vulnhub.com/entry/metasploitable-2,29/

File: metasploitable-linux-2.0.0.zip (833 MB)

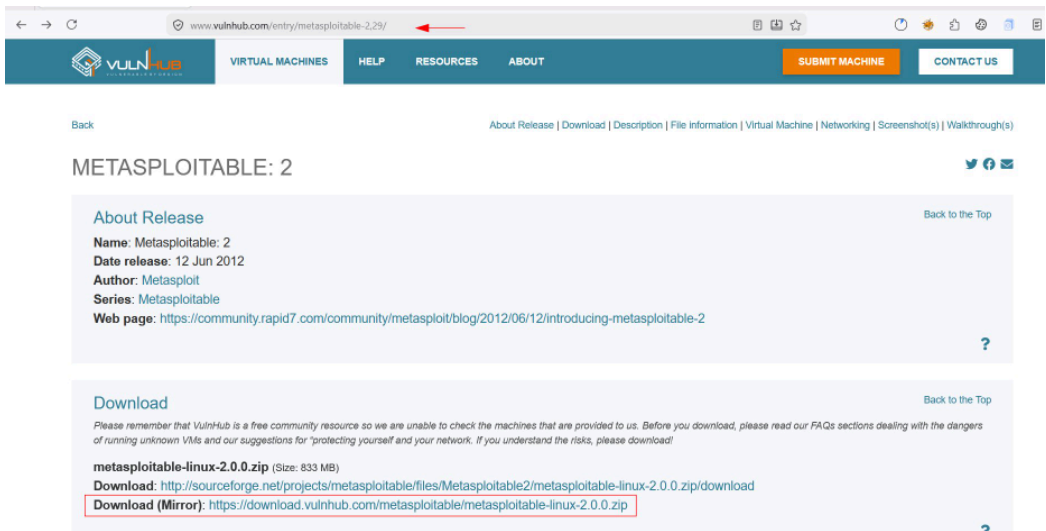


Fig 1 – VulnHub entry page for Metasploitable 2 showing download mirror link

8.2 Step 2 – VirtualBox & Host-Only Network Setup

The .vmdk was imported into Oracle VM VirtualBox. The network adapter was set to Host-Only – fully isolating the target from any external or internet-connected network.

Setting	Value
VM Name	Metasploitable2
OS Type	Other Linux (32-bit)
Base Memory	256 MB
Storage	Metasploitable.vmdk – 8.00 GB (SATA)
Network Adapter	Intel PRO/1000 MT Desktop – Host-Only Adapter

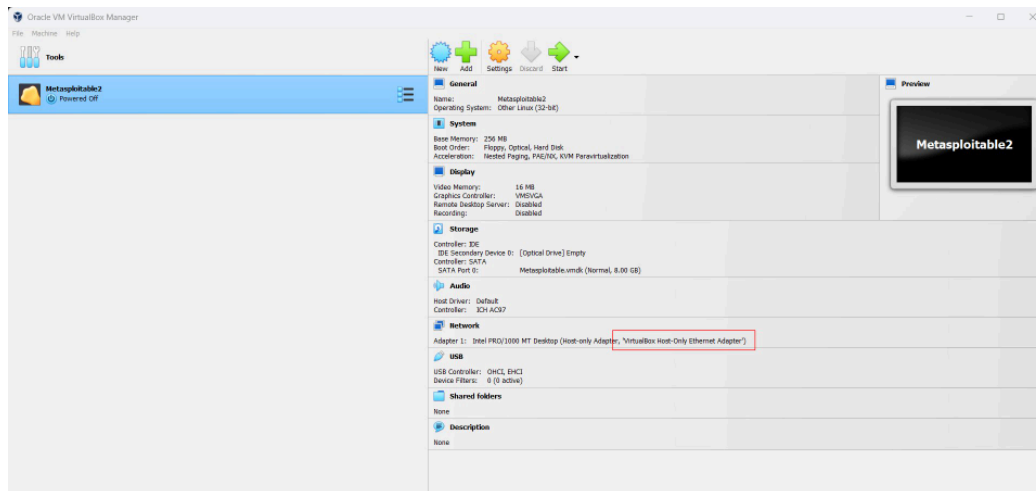


Fig 2 – VirtualBox Manager showing Metasploitable2 VM with Host-Only network adapter highlighted

8.3 Step 3 – Host Discovery (ARP Scan + netexec)

Target IP was confirmed via ARP scan. netexec was then used to fingerprint the SMB service and gather host information.

ARP Scan

```
$ arp-scan -localnet
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.56.105	08:00:27:1b:2d:a2	1	60	PCS Systemtechnik GmbH

netexec SMB Fingerprint

```
$ netexec smb 192.168.56.105
SMB 192.168.56.105 445 METASPLOITABLE
[*] Unix (name:METASPLOITABLE) (domain:localdomain)
[*] signing:False (SMBv1:True) (Null Auth:True)
```

```
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
1 Captured ARP Req/Rep packets, from 1 hosts. Total size: 60
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.56.105	08:00:27:1b:2d:a2	1	60	PCS Systemtechnik GmbH

```

root@kali:~/home/kali# netexec smb 192.168.56.105
SMB 192.168.56.105 445 METASPLOITABLE [*] Unix (name:METASPLOITABLE) (domain:localdomain) (signing:False) (SMBv1:True) (Null Auth:True)

```

Fig 3 – ARP scan result and netexec SMB fingerprint confirming target at 192.168.56.105

Critical: SMBv1 enabled + null authentication + no signing = direct exploitation via CVE-2007-2447 (unauthenticated root shell) requiring zero credentials.

8.4 Step 4 – Nmap Aggressive Scan

Nmap -A enables OS detection, version detection, NSE script scanning, and traceroute. Output saved to nmap-agg. Full scan completed in 22.35 seconds across 23 open ports.

Command

```
$ nmap -A 192.168.56.105 -oN nmap-agg
```

Screenshot 1 – FTP, SSH, Telnet, SMTP (Ports 21, 22, 23, 25)

```
(root@kali) ~ /home/kali
$ nmap -A 192.168.56.105 -oN nmap-agg
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-10 03:58 -0400
nmap_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid servers with --dns-servers: No such file or directory (2)
nmap_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.105
Host is up (0.00050s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp           vsftpd 2.3.4
ftp-syst:
  STAT:
  FTP server status:
    Connected to 192.168.56.106
    Logged in as ftp
    TYPE: ASCII
    No session bandwidth limit
    Session timeout in seconds is 300
    Control connection is plain text
    Data connections will be plain text
    vsftpd 2.3.4 - secure, fast, stable
  End of status
22/tcp    open  ssh           OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
ssh-hostkey:
  1024 60:0f:cf:1c:05:f6:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet        Linux telnetd
25/tcp    open  smtp          Postfix smtpd
sslv2:
  SSLv2 supported
ciphers:
  SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
  SSL2_RC4_128_EXPORT40_WITH_MD5
  SSL2_DES_192_EDE3_CBC_WITH_MD5
  SSL2_RC2_128_CBC_WITH_MD5
  SSL2_DES_64_CBC_WITH_MD5
  SSL2_RC4_128_WITH_MD5
ssl-cert: Subject: commonName=ubuntu@804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
Not valid before: 2010-03-17T14:07:45
Not valid after: 2010-04-10T14:07:45
```

Fig 4a – Ports 21 (vsftpd 2.3.4 | CVSS 10.0), 22 (OpenSSH 4.7p1), 23 (Telnet | CVSS 7.4), 25 (SMTP/SSLv2)

vsftpd 2.3.4: CVE-2011-2523 (CVSS 10.0) – inserting ':' in the username field triggers a root shell on port 6200. One of the most well-known deliberate backdoors in any software package.

Screenshot 2 – DNS, HTTP, RPC, Samba, MySQL, PostgreSQL (Ports 53, 80, 111, 139, 445, 1524, 3306, 5432)

```
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl-date: 2026-06-10T07:58:45+00:00; 41s from scanner time.
53/tcp    open  domain        ISC BIND 9.4.2
|_dns-nsid:
|_bind.version: 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind        2 (RPC #100000)
|_rpcinfo:
|_program version    port/proto  service
|_100000 2                111/tcp    rpcbind
|_100000 2                111/udp    rpcbind
|_100003 2,3,4            2049/tcp   nfs
|_100003 2,3,4            2049/udp   nfs
|_100005 1,2,3            45981/tcp  mountd
|_100005 1,2,3            45972/udp  mountd
|_100021 1,3,4            41669/udp  nlockmgr
|_100021 1,3,4            48691/tcp  nlockmgr
|_100024 1                59427/tcp  status
|_100024 1                60984/udp  status
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login          OpenBSD or Solaris rlogind
514/tcp   open  shell          Netkit rshd
1099/tcp  open  java-rmi       GNU Classpath gmrregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
|_mysql-info:
|_Protocol: 10
|_Version: 5.0.51a-3ubuntu5
|_Thread ID: 8
|_Capabilities flags: 43564
|_Some Capabilities: Speaks41ProtocolNew, SwitchToSSLAfterHandshake, SupportsCompression, SupportsTransactions, ConnectWithDatabase, LongColumnFlag, Support
41Auth
|_Status: Autocommit
|_Salt: 5g$/^lbr2@)(1Z/x48]
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-cert: Subject: commonName=ubuntu@804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
```

Fig 4b – Ports 53 (BIND 9.4.2), 80 (Apache 2.2.8), 111 (RPC/NFS), 139/445 (Samba 3.0.20 | CVSS 10.0), 1524 (root shell), 3306 (MySQL), 5432 (PostgreSQL)

Samba 3.0.20 (139/445): CVE-2007-2447 (CVSS 10.0) – unauthenticated RCE as root via username map script. Port 1524: pre-opened root bindshell – connecting directly gives instant root. MySQL: root account has no password (CVSS 9.8).

Screenshot 3 – VNC, X11, IRC, AJP, Tomcat, OS Detection (Ports 5900, 6000, 6667, 8009, 8180)

```

| Not valid before: 2010-03-17T14:07:45
| Not valid after: 2010-04-16T14:07:45
| _ssl-date: 2026-06-10T07:38:45+00:00; +1s from scanner time.
5900/tcp open  vnc          VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|     VNC Authentication (2)
6000/tcp open  x11            (access denied)
6667/tcp open  irc            UnrealIRCd
8009/tcp open  ajp13          Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http           Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5
MAC Address: 08:00:27:1B:2D:A2 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_ smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-06-10T03:58:37-04:00
|_  smb2-time: Protocol negotiation failed (SMB2)
|_  clock-skew: mean: 1h00m00s, deviation: 2h00m00s, median: 0s
|_  nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

TRACEROUTE

```

Fig 4c – Ports 5900 (VNC 3.3), 6000 (X11), 6667 (UnrealIRCd | CVSS 10.0), 8009 (AJP Ghostcat | CVSS 9.8), 8180 (Tomcat 5.5), OS: Linux 2.6.9-2.6.33

UnrealIRCd (6667): CVE-2010-2075 (CVSS 10.0) – deliberate backdoor; unauthenticated RCE as root. AJP (8009): CVE-2020-1938 Ghostcat (CVSS 9.8) – arbitrary file read and RCE. Linux 2.6.x kernel: end-of-life, no vendor security updates.

Screenshot 4 – Traceroute & Scan Summary

```

TRACEROUTE
HOP RTT ADDRESS
1 0.56 ms 192.168.56.105

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.35 seconds

```

Fig 4d – Traceroute: 1 hop, 0.56ms | Scan complete: 23 ports open, 22.35 seconds

8.5 Step 5 – Attack Surface Map

The full 23-port attack surface map with all CVE, CWE, CVSS 3.1, and OWASP (2025) mappings is presented in Section 7 of this report.

9. Key Risks & Recommendations

Priority remediation actions required in any real-world environment equivalent to this configuration:

- **CRITICAL** – Remove vsftpd 2.3.4 & UnrealIRCd: Both contain deliberate backdoors (CVE-2011-2523, CVE-2010-2075). No patch exists – reinstall from clean verified sources.
- **CRITICAL** – Close open bindshell (port 1524): Provides root with zero authentication. Remove entirely – no legitimate use case.
- **CRITICAL** – Patch Samba (CVE-2007-2447): Upgrade to supported release; disable username map scripts. Exploitable in seconds via Metasploit.
- **HIGH** – Disable SMBv1 + enforce signing: SMBv1 is obsolete and actively exploited. Firewall at OS and network level.

- HIGH — Retire plaintext protocols (Telnet, rsh, rlogin, rexec): Enforce SSH exclusively. All r-services should be removed.
- HIGH — Disable AJP connector (Ghostcat CVE-2020-1938): Firewall port 8009 unless strictly required. Upgrade Tomcat.
- HIGH — Set MySQL root password + restrict remote access: Root currently has no password (CVSS 9.8).
- MEDIUM — Restrict NFS/RPC: allowlist IPs in /etc/exports; firewall ports 111 and 2049 from untrusted networks.
- MEDIUM — Upgrade all EOL software: Linux 2.6.x, Apache 2.2.x, Tomcat 5.5, OpenSSH 4.7 — all unsupported.
- MEDIUM — Disable zone transfers (DNS): Restrict AXFR queries to authorised secondaries only.

10. Disclaimer & Legal Notice

This penetration test was conducted exclusively within an authorised, isolated laboratory environment using Metasploitable 2, a virtual machine intentionally created for security research and educational purposes by Rapid7/Metasploit. No production systems, live networks, third-party infrastructure, or any systems without explicit written authorisation were targeted at any point.

All activities documented in this report are lawful within the defined lab scope. Techniques and tools referenced are standard within the information security industry and are used solely under the SkillsQuark curriculum for defensive research and skills development.

© 2026 SkillsQuark | Security Research & Training Division | Classification: CONFIDENTIAL